Multi-Agent AI for Smart Contract Audit and Cybersecurity Risk Assessment

Investigate smart contract risks through reproducible checks, independent model reviews and source-linked evidence.

THE CONTEXT

Code governs the asset

Smart contracts encode permissions, transfers and interactions in digital asset workflows. A defect in those controls can affect custody, transaction integrity or availability.

THE REVIEW PROBLEM

A finding needs evidence

A recognizable pattern may be benign in context. Model explanations may disagree. Reviewers need the relevant source, the reasoning behind each claim and a record of differences.

THE PLATFORM RESPONSE

Make findings inspectable

Combine an independent static baseline with three model reviews. Validate cited source evidence, reconcile compatible findings and preserve the original contributions for review.

CONNECT TECHNICAL FINDINGS TO DIGITAL ASSET EXPOSURE

Review question	Potential exposure	Evidence to inspect
Who can change or move value?	Unauthorized actions or asset transfers	Caller checks, state changes and recipients
What happens across a contract call?	Repeated withdrawals or inconsistent state	Call order, state updates and return values
Which assumptions drive outcomes?	Manipulated payouts or unavailable functions	Inputs, timing, randomness and iteration

Independent findings. Deliberate second review.

Use Static Analysis or Bedrock Review, then inspect findings before starting a separate second round.

STATIC ANALYSIS

Run Static Analysis

15 pattern rules inspect the submitted source in the browser. No API key or backend is required.

The source stays on-device in this mode. Results provide a reproducible baseline with matched lines and recommended review actions.

BEDROCK REVIEW

Run Bedrock Review

Three parallel model reviews, using one Bedrock key: GPT-6 Astra, Claude Opus 5.5 and Grok 4.7.

Inspect Findings first. Open Second Review and select Run Second Review for eligible claims; it can add up to nine calls.

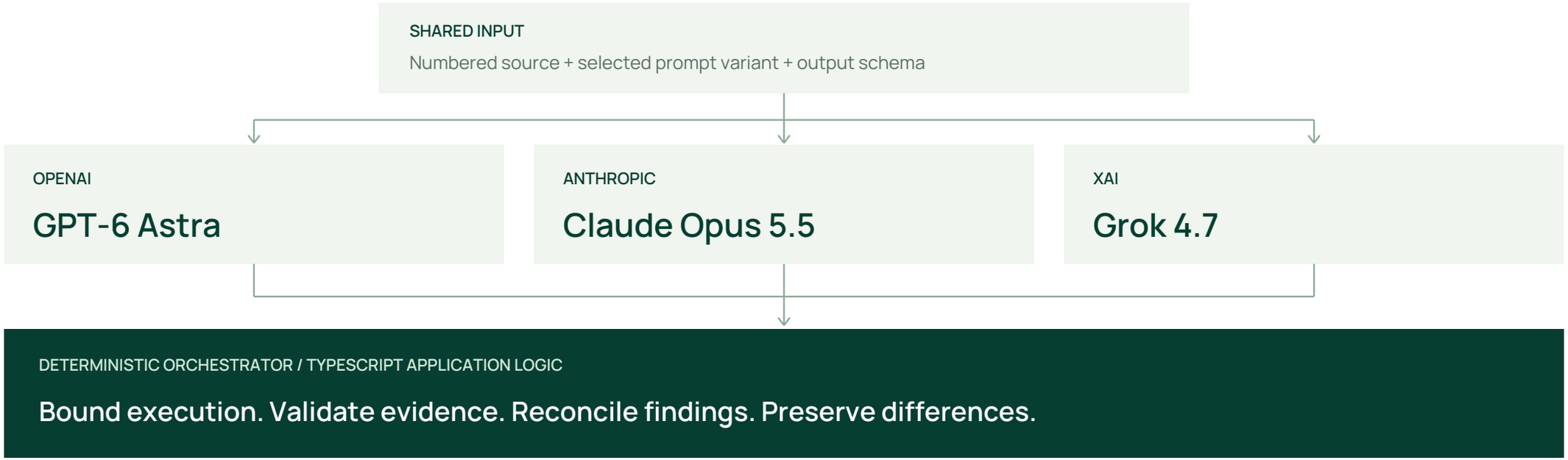
FROM SOURCE TO REVIEWABLE RESULTS

Task	Workspace interaction	Review output
Add contract	Choose an example, upload a contract or paste code	A numbered source snapshot, kept with its review
Review	Run Bedrock Review; inspect Findings	Independent model findings, evidence and agreement
Report	Run Second Review, then select View Final Report	Original findings, later judgments and unresolved issues

The hosted website supports the complete browser workflow. The same workspace can also run locally from the repository.

Independent reviews. Explicit orchestration.

Three independent model tasks share bounded execution and one deterministic reconciliation process.



01 Supervise

Use one spare attempt for eligible service errors or a Second Review validation correction. Keep the deadline and accepted peers.

02 Validate & reconcile

Accept exact source evidence, then match compatible weaknesses. Keep ambiguous claims separate.

03 Preserve

Retain individual model outcomes and original findings so reviewers can inspect each contribution.

Initial prompts exclude static findings and peer answers. Second Review requires an explicit action and the exact initial record.

Evidence validation and model agreement

Inspect what was checked, how many models support a claim and how its proposed severity was selected.

SOURCE EVIDENCE ACCEPTANCE

01 Validate the response structure

Second Review uses 12 stable slots: assigned answers are explicit; unused slots must be null. Validated answers bind to trusted IDs.

02 Bind the evidence to the source

All models cite source spans in both rounds. The app checks valid spans of at most 12 lines and retrieves the exact original text.

03 Record the server's validation

The server records source validation only after these checks pass. A model cannot certify its own evidence as verified.

MODEL AGREEMENT

1 / 3	2 / 3	3 / 3
LOW	MEDIUM	HIGH

Each distinct supporting model counts once. Duplicate findings add no votes. Static matches and missing model results add no votes; the denominator remains three.

SEVERITY & DIFFERENCES

The highest proposed severity is displayed. Severity differences and incomplete support identify claims to compare. First-pass agreement remains unchanged after any peer-informed second review.

A HIGH-severity finding may have LOW agreement (1 / 3 models).

Severity expresses proposed impact; agreement expresses breadth of model support. Both remain available for review.

Source matching does not prove exploitability. Agreement is not a calibrated probability of correctness.

Reconsider differences. Keep the evidence.

Start Second Review explicitly after inspecting Findings; initial evidence and independent agreement stay unchanged.

Open Second Review, inspect assignments, then select Run Second Review. Successful initial reviewers reconsider peer omissions and severity disputes; failed initial models remain unavailable.

12 claims

DETERMINISTIC SELECTION

Remaining queue entries are deferred.

2+ reviewers

FIRST-PASS ELIGIBILITY

Empty assignments make no provider call.

1 round

BOUNDED SECOND ROUND

At most nine additional provider requests.

Effective model positions	Final disposition	Meaning for the reviewer
All three support; provenance retained	Supported	Severity differences and pending reassessment still require review
All three explicitly reject the claim	Not supported	A model conclusion, not a certified false positive
Mixed, uncertain, missing or deferred	Unresolved	Retain differences and incomplete coverage for human review

A failed reassessment retains valid original support and severity, with pending work marked explicitly.

Final Report follows an accepted second-round result or an ineligibility reason. Retained evidence is not a new second-round vote.

Read the risk. Decide the next action.

Start with risk priority, the source-grounded explanation and recommended action; expand the evidence when needed.

REPRESENTATIVE STATIC RISK FAMILIES

Access control & custody

tx.origin authorization, ownership changes and asset-transfer patterns.

External interactions

Calls before balance updates, unchecked call/send results and caller-controlled callbacks.

Execution authority

delegatecall and selfdestruct expressions, with their target and authorization assumptions.

Economic & time assumptions

Block-data randomness, predictable game outcomes and timestamp-sensitive logic.

Configuration & availability

Legacy or missing compiler declarations and potentially unbounded iteration.

FINAL REPORT & AUDIT TRAIL

Risk	Severity overview, the reported risk and a concrete recommended action.
Run	Coverage across both rounds, pending reassessments and retained original opinions.
Models	Expandable model judgments and exact source evidence retain the audit trail.

EXPORT FOR FOLLOW-UP

JSON	Final finding ledger, unchanged original rounds, per-model judgments and source provenance.
Markdown	Risk summary, reported explanations, recommended actions and model-judgment history.

Review scope: one Solidity source file. Contracts are not compiled, imports are not resolved and exploits are not executed.

Bounded execution. Controlled evaluation.

Inspect operational reliability on the same five contracts before drawing conclusions about detection quality.

3 attempts

PER MODEL / PASS, MAXIMUM

Shared by service retries, output-limit recovery and evidence correction.

11 minutes

LOCAL MODEL DEADLINE

12 minutes per round locally. Vercel uses a shorter hosting budget.

90 calls

FIVE CASES WITH BOTH PASSES, MAXIMUM

First pass only: 45 calls. Second review is optional.

FIRST-PASS PROMPT COMPARISON

Standard prompt

Shared review instructions and output schema provide the baseline for all three models.

Guided examples

Separate synthetic examples illustrate grounded claims and benign lookalikes. No reference-case answers or peer findings are supplied.

FIVE-CASE VALIDATION

01 Fix the conditions

Keep the five benchmark sources fixed. DAO Treasury is a separate case with no preset finding count.

02 Run sequentially

Pair each second review with its own first-pass report. Cancel to stop new work and keep completed records.

03 Adjudicate and compare

Import source-bound human labels. Precision needs reviewed predictions; recall needs a complete issue inventory.

Content-filter and guardrail blocks are terminal. The app does not retry or rewrite input to bypass them.

Keep the other results. Ask the AWS administrator/provider to review permitted use if the blocked model is required.

Cancellation cannot reverse work already accepted by AWS. Returned token totals may omit usage from failed attempts.

Connect, review and share from your browser.

Use a valid Amazon Bedrock key with access to the three configured models in US East (N. Virginia).

BROWSER WORKFLOW

01 Prepare your source

Select DAO Treasury under Reference cases, upload one .sol file or edit the source.

02 Connect Bedrock

Select Bedrock Review, paste the key and choose Use API key. Saving checks format; it does not start paid work.

03 Run Bedrock Review

Inspect Findings after the first round. Open Second Review, then explicitly select Run Second Review.

04 Read, export and clear

Select View Final Report after an accepted second-round result or stated ineligibility. Export before refreshing or clearing the key.

FIRST-PASS MODEL COVERAGE

Completed	3 / 3 models returned validated reviews.
Partial	1 or 2 succeeded. Their reviews remain available; failures stay explicit.
Failed	No validated model review is available. The independent static baseline remains usable.

If a model exhausts its output budget, its partial response is discarded. One retry can raise its allowance from 32,768 to 65,536 tokens.

Two completed assigned second reviews can still mean only 2 / 3 initial reviews. No completed run establishes safety.

OPEN THE PLATFORM

dtcc-multi-agent-audit.vercel.app

ORCHESTRATION DESIGN

Independent review, reconsideration and evaluation - three-page brief

DOCUMENTATION

Read and download both platform documents